



JUNE 14, 2026 · REF: 001
TARGET: TESTASP.VULNWEB.COM
PREPARED FOR: VULNWEB PLATFORM
MANAGEMENT

PASSIVE SECURITY & CONFIGURATION

AUDIT REPORT



Tracking Repository
[github.com/bondidhanush01-bit/-
FUTURE_CS_01](https://github.com/bondidhanush01-bit/-FUTURE_CS_01)



Executive Summary & Audit Methodology

This audit was performed as a non-intrusive configuration assessment of <http://testasp.vulnweb.com/>, focusing exclusively on public-facing files and passive inspection layers. All findings are derived from observable, publicly accessible data without any active exploitation techniques.

Passive Inspection Only

Assessment limited to passive observation of public-facing configuration signals and response metadata.

No Active Testing Methods

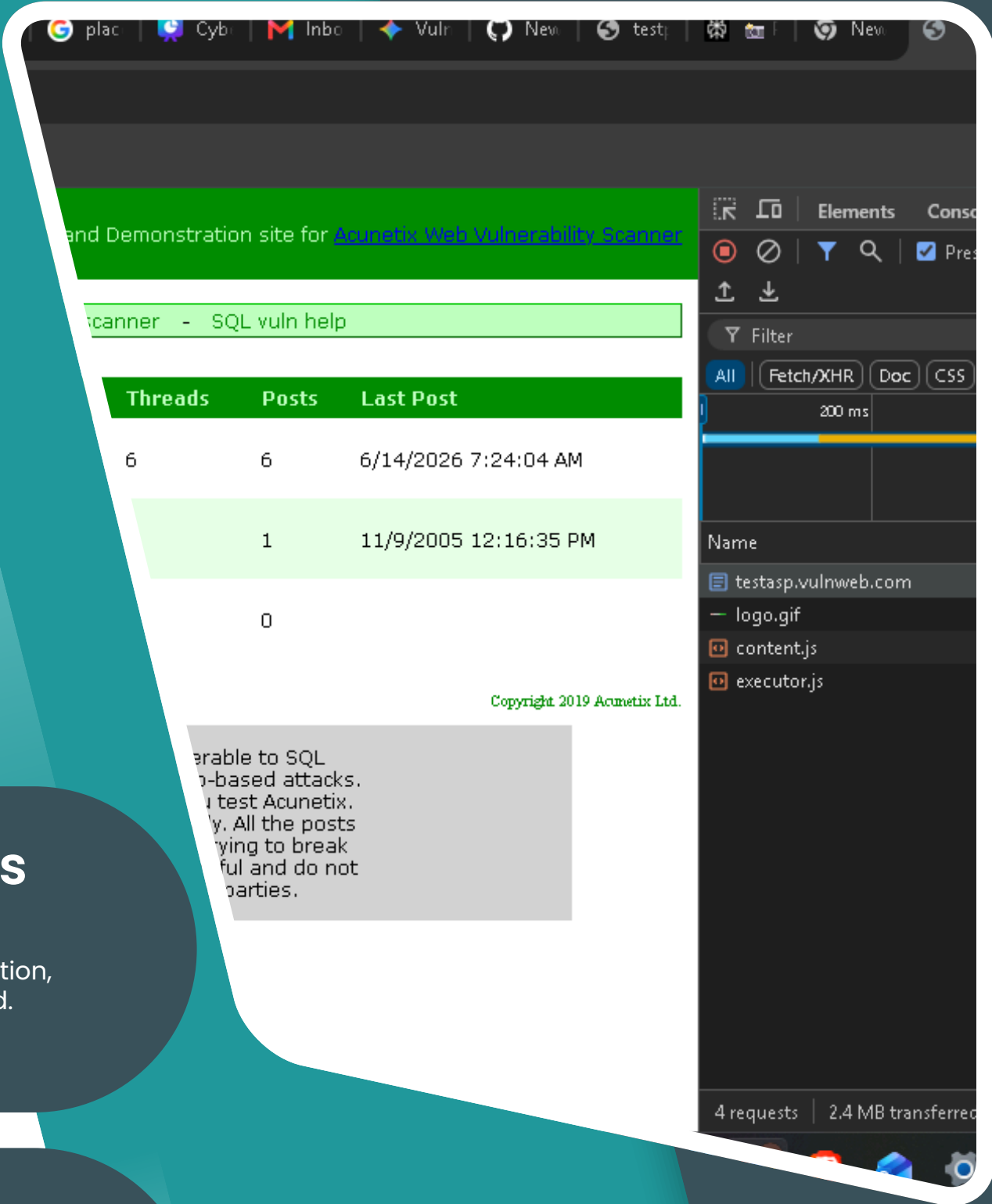
No authentication bypass, brute force, payload injection, fuzzing, or intrusive probing techniques were used.

Evaluated Artifacts

Reviewed server banners, HTTP response header streams, public directory paths, and browser defensive policies.

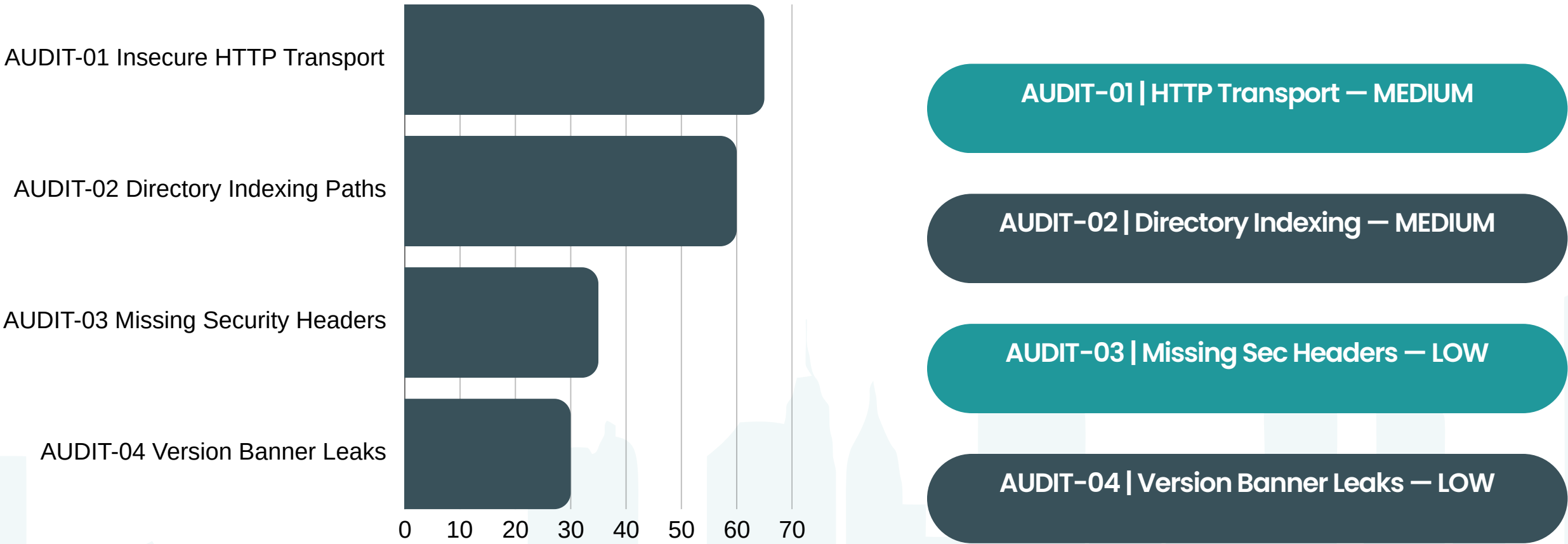
Rules of Engagement

Audit conducted in full compliance with passive inspection rules of engagement and non-intrusive assessment standards.



Audited Vulnerability & Configuration Ledger

Passive configuration assessment of <http://testasp.vulnweb.com> — 4 findings identified across transport security, infrastructure misconfiguration, browser defensive policies, and environment configuration. Risk levels: Amber Orange = MEDIUM (Immediate/High Priority); Slate Blue = LOW (Next Cycle).



Source: AI-generated data. Replace or verify before use.

Medium Risk Finding #1

Finding ID: AUDIT-01 | Risk Level: MEDIUM | Category: Data-In-Transit Encryption | Urgency: Immediate Attention

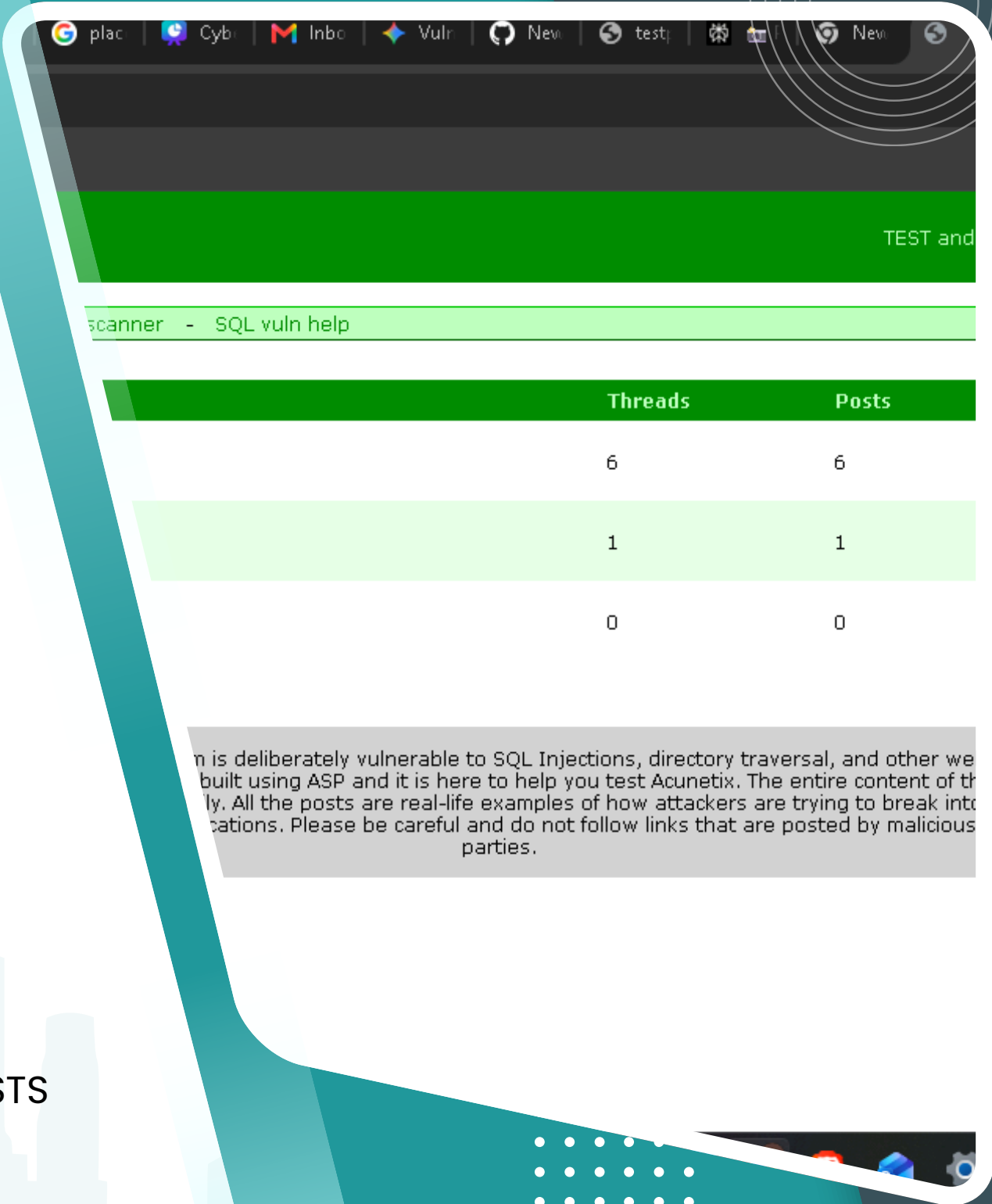
Insecure Plaintext Transport Infrastructure (HTTP Only)

The entire testasp.vulnweb.com platform operates exclusively over unencrypted HTTP. No TLS/SSL layer or forced HTTPS redirection was detected during passive inspection. Modern browsers display a "Not secure" warning in the address bar, eroding visitor trust immediately.

Business Impact: Exposure of all transmitted data to interception on public networks; SEO ranking penalty from search engines; form submissions and session tokens transmitted in plaintext.

Auditor Remediation Guidance

Deploy a valid SSL/TLS certificate (e.g., Let's Encrypt — free, automated) and configure the web server to enforce a permanent redirect from HTTP port 80 to HTTPS port 443. Ensure HSTS header is added post-deployment.



Medium Risk Finding #2

Finding ID: AUDIT-02 — Unprotected Directory Indexing Paths (/admin, /CVS)

Risk Level: MEDIUM | Category: Infrastructure Misconfiguration | Urgency: High Priority

Non-Technical Summary: The web server openly lists directory contents when no index page is present. Paths such as /admin/ and /CVS/ return a full directory listing instead of a 403 Forbidden response, exposing internal file names and folder structures to any visitor.

Technical Evidence: Passive inspection of `http://testasp.vulnweb.com/admin/` and `/CVS/` confirms the server returns "Index of /" directory listings rather than denying access. No authentication or access control is enforced on these paths.

Business Impact & Remediation

Business Impact: Reveals internal file structure, backup scripts, and admin assets — directly aiding attackers in mapping the application layout and identifying targets for further exploitation.

Auditor Remediation: Disable directory indexing globally via web server configuration. For Apache: set "Options -Indexes" in `httpd.conf` or `.htaccess`. For IIS: disable directory browsing in site settings. Restrict /admin and /CVS paths with explicit access deny rules.

testasp.vulnweb.com/index/ is a vulnerability (tamara) for educational purposes

ms testasp.vulnweb

Microsoft SQL Server vulnweb +1

Web Vulnerability Scanner vuln

Vulnerabilities

Low Risk Finding #1

Total Absence of Browser Defensive Security Headers

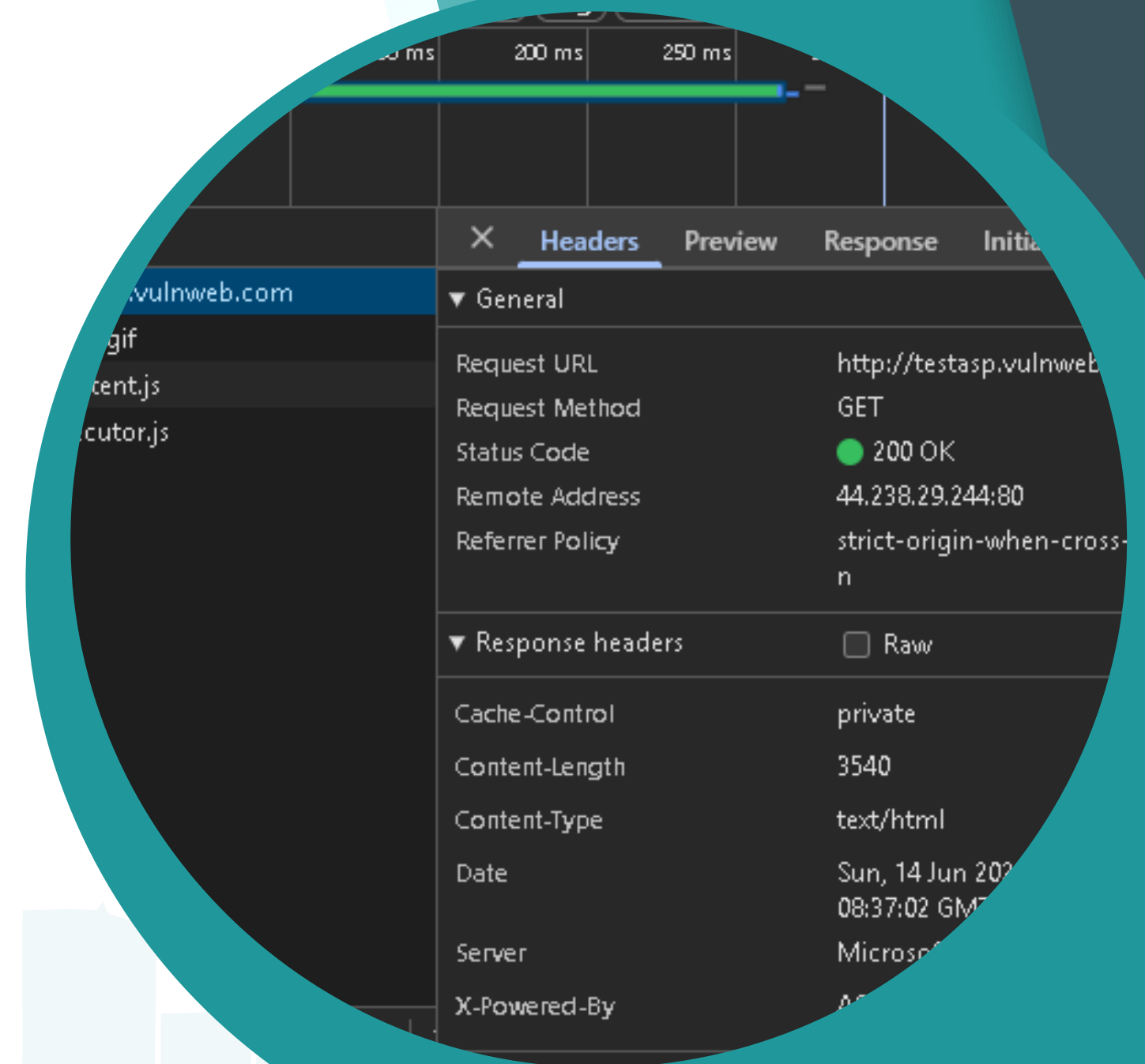
The public-facing application returns HTTP responses with no browser security headers present. Passive header inspection confirms complete absence of X-Frame-Options, Content-Security-Policy, and X-Content-Type-Options. This exposes end users to UI redress (clickjacking) attacks, MIME-type sniffing exploits, and cross-site injection risks without any browser-level mitigation layer.

LOW RISK — Slate Blue

Auditor Remediation — Add the following headers in server config or routing logic:

- X-Frame-Options: DENY
- X-Content-Type-Options: nosniff
- Content-Security-Policy: default-src 'self';

Business Impact: Reduced protection against UI attacks; browsers cannot enforce content isolation policies. Schedule for next deployment cycle.



Low Risk Finding #2 — Verbose Version Banner Leaks

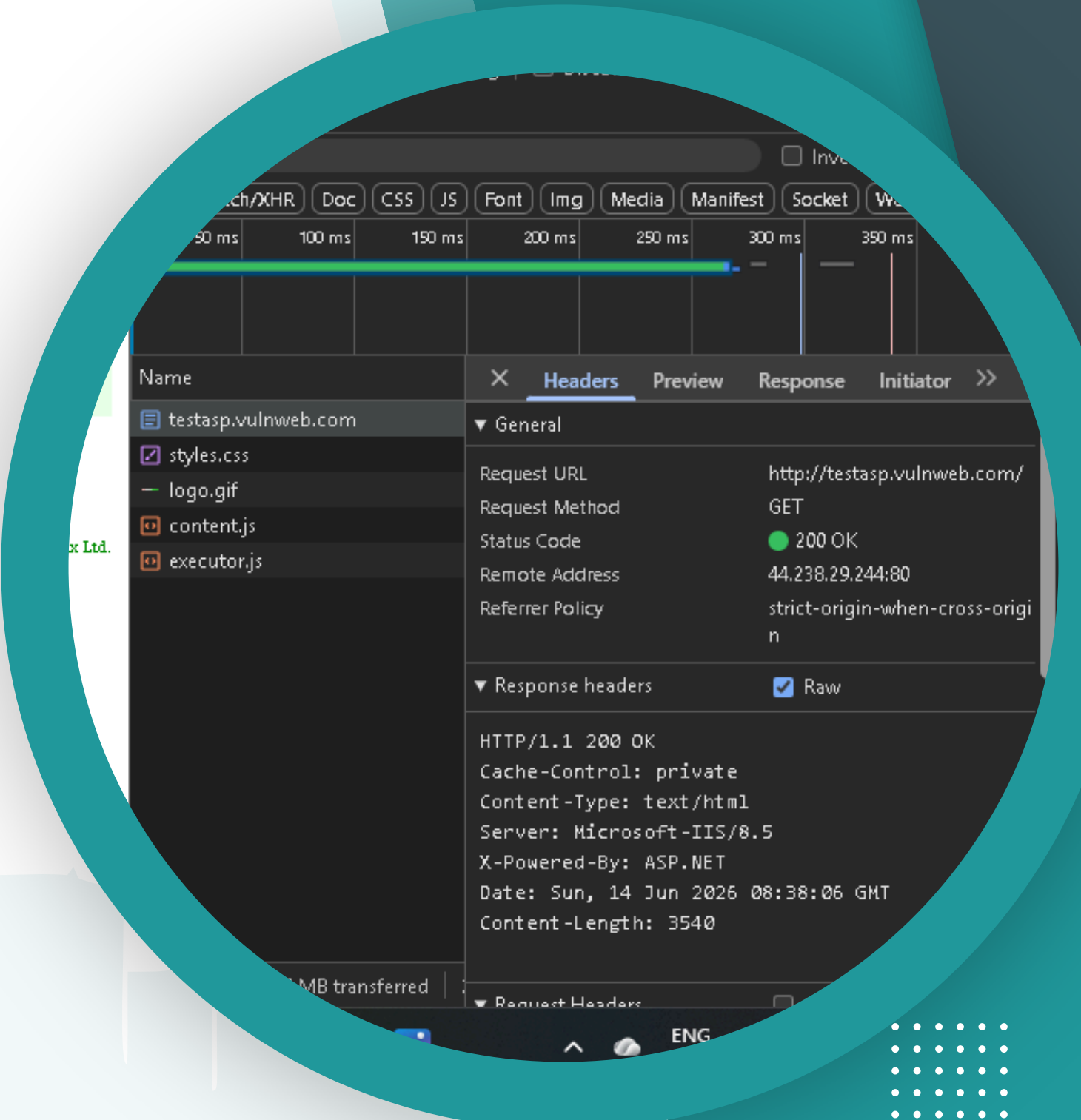
Non-Technical Summary: The web server exposes exact software version strings in HTTP response headers, including Server: Microsoft-IIS/7.5, X-Powered-By: ASP.NET, and X-AspNet-Version: 2.0.50727. This aids attacker fingerprinting and targeted exploit selection.

Technical Evidence: Passive network header capture during public page load confirms verbose banner disclosure. No suppression or redaction of version identifiers is applied at the server or application layer.

LOW RISK — Slate Blue

Business Impact: Exposes exact platform stack to reconnaissance; enables targeted CVE lookups against known IIS 7.5 and ASP.NET 2.0 vulnerabilities.

Auditor Remediation: Suppress verbose banners via web.config modifications for IIS/ASP.NET — set customErrors mode, remove X-Powered-By and X-AspNet-Version headers, and disable detailed server error messages. Risk Level: LOW — Next Maintenance Window.



Recommendations Summary

MEDIUM Priority

Immediate Attention (Within 14 Days):

- Deploy valid SSL/TLS certificate (e.g., Let's Encrypt) and enforce HTTPS redirect from port 80 to 443.
- Disable directory indexing globally via web server configuration (Options -Indexes in httpd.conf or .htaccess).

Verification: SSL Labs for SSL configuration validation.

LOW Priority

Next Deployment Cycle (Within 60 Days):

- Implement missing browser security headers: X-Frame-Options: DENY, X-Content-Type-Options: nosniff, Content-Security-Policy: default-src 'self'.
- Suppress verbose version banners (Server, X-Powered-By, X-AspNet-Version) via web.config.

Verification: Security Headers scanner; Browser Developer Tools.

Follow-Up Audit

A follow-up passive configuration audit is recommended 90 days after remediation completion to verify all fixes have been applied and no new configuration defects have been introduced.